EDP-Lambda For AV Scanning Of S3 Buckets

Table Of Contents

- Pattern Summary
  - Description
    - Antivirus for Amazon S3
    - Event-Driven Scanning
    - Two Bucket System
    - Three Bucket System
  - Diagram
  - Use Cases
  - Goals & Benefits
  - Limitations
  - Components/Services
  - When To Use
  - Related Patterns
- Security
- Cost Model
- Deployment Strategy
- Review History
- Appendix
  - References

Column Name	*Column Value*	*Column Reference Guide*
Pattern ID	EDP-4	Alpha numeric unique identifier to identify/reference the pattern. Forma The number(N) is a running value and is not auto generated. This need entered based on the last numeric value in the design pattern catalog e numeric value of pattern # in the design pattern catalog is EDP-10 ther it would be EDP-11. The catalog referenced here is catalog in Confluenc Engineering Design Patterns
Pattern Name	Lambda For AV Scanning Of S3 Buckets	Name of the design pattern
Type	Infrastructure	Pattern Classification : Type as per TBM Taxonomy Structure Refer link for the value list Technology Business Management (TBM) Ta Structure
Category	Compute	Pattern Classification : Category for given type as per TBM Taxonomy S Refer link for the value list Technology Business Management (TBM) Ta Structure
Name	Virtual Compute & Containers	Pattern Classification : Name for given type & category as per TBM Tax Refer link for the value list Technology Business Management (TBM) Ta Structure
Cloud Specific	Yes	Is the design pattern cloud specific ? (Yes, No)
Cloud Service Provider(s)	AWS	If Cloud Specific value is No, provide value for Cloud Service Provider If Cloud Specific is Yes, provide cloud provider from the list AWS, GCP, than 1 cloud, provide the values in comma separated format e.g. if AWS cloud providers for the given pattern then provide the value as AWS, G
Service Offering(s)	AV, S3	List the the service offering(s) documentation link to which the design p to. If there are more than 1 service offering, list each service offering pa comma separated format e.g. Service Offering 1, Service Offering 2
Status	APPROVED	Default status is DRAFT when the page is created from template . Othe are : APPROVED(Green), DRAFT(Dark Grey), IN REVIEW(BLUE), REVIE To update the status, click the status value → select edit → enter the st select the color and click save
Solution Architect	@Brent Thompson	Solution architect for the design pattern (use "@" for the name i.e. @us
Reviewer(s)		Reviewer(s) for the design pattern (use "@" for the name i.e. @usernan
Approver(s)	@Aladdin Al-Haj Mustafa (Deactivated)	Approver(s) for the design pattern (use "@" for the name i.e. @usernar
Approved Date	Jan 19, 2024	Date the pattern was approved . Use "//" to specify the date

Pattern Summary

Description

NOTE: This is a tactical solution for the FlyWheel project as they have an implementation deadline end of January 2024. CL Security is looking to standardize an antivirus solution sometime in 2024. This pattern will be updated depending on the outcome of a standardized antivirus solution for CL. This pattern recommends for an antivirus solution a buy vs. build from the Amazon Marketplace.

A wide range of solutions ingest data, store it in Amazon S3 buckets, and then share it with downstream users or systems. In certain use cases, the ingested data is coming from third-party sources, which opens the door to potentially malicious files—objects that may be infected with malware, viruses, ransomware, trojan horses, and more.

Canada Life could be exposed to the risk of malicious files, the application's downstream users and/or systems are also exposed to potential malware infection on either their local devices in case of a user or in case of a system, a downstream application tier or process.

If a customer, partner, internal user, process or application downloads and opens an infected file, it can cause harm to the recipient's system, as well as reputational risk, lost customers, and potential lost revenue for the organization that allowed it to be shared.

To minimize negative upstream and downstream risk, Canada Life will need to scan all objects in a publicly exposed S3 bucket.

The following pattern will include the following assumptions:

- The service Antivirus for Amazon S3 is required and is available on the AWS Marketplace.
- A choice of either Sophos or ClamAV is required as these are the only supported anti-virus engines by Antivirus for Amazon S3.
- Event-Driven scanning will be used as this is the recommended approach by AWS.
- The pattern will include two options:
  - a minimum of two S3 buckets, one for staging, and one production.
  - or a 2nd option for consideration which includes three S3 buckets, staging, quarantine and production
- The 2nd option may not be required but is added for completness. This option would be used if CL Security teams want a copy of infected files for future analysis.

Antivirus for Amazon S3

Antivirus for Amazon S3 is a 3rd party service available on Amazon Marketplace that enables users to detect files infected with malware and viruses using a variety of scanning models.

Currently, two scanning engines are available out of the box: Sophos and ClamAV. When a file is uploaded to Amazon S3, Antivirus for Amazon S3 scans the file using the scanning engine of your choice to detect malicious content. Both engines can be used together for even higher efficacy.

With event-based scanning, the default behaviour is to quarantine infected files for further review to protect against the spread of malware. However, this policy can be modified.

The solution is deployed within a AWS account through the use of an AWS CloudFormation template. The resulting infrastructure is an AWS Fargate serverless solution.

Once deployed, Amazon S3 buckets will be auto-discovered and cataloged for any connected AWS accounts. Antivirus for Amazon S3 can baseline existing data, as well as all new data, including files as large as 5 TB in size (the maximum individual object size allowed by Amazon S3). In the case of this pattern, we would only create a policy to scan the FlyWheel public S3 staging bucket and not all S3 buckets in all accounts.

This pattern recommends the use of the service Antivirus for Amazon S3 as this service will manage:

- The container environment
- Virus updates
- and patches or updates required by the service

We can look at a build vs buy system once a standardized antivirus solution is published at CL.

Event-Driven Scanning

Event-driven scanning is the easiest and fastest route to scan files in Amazon S3 buckets when the scanning requirement allows for near real-time scanning of files after they are written to S3. Amazon S3 buckets can be configured to raise an event any time an object is stored or modified within the bucket.

Antivirus for Amazon S3 leverages a direct integration with this model to listen for those events and push them to an Amazon Simple Notification Service (Amazon SNS) topic with a subscribed Amazon Simple Queue Service (Amazon SQS).

This fanout approach allows your internal workflows, as well as the scanning workflow, to properly operate without impacting one another. Event-driven scanning means that when a bucket is protected by Antivirus for Amazon S3, any object stored or modified in that bucket will automatically be scanned in near real-time.

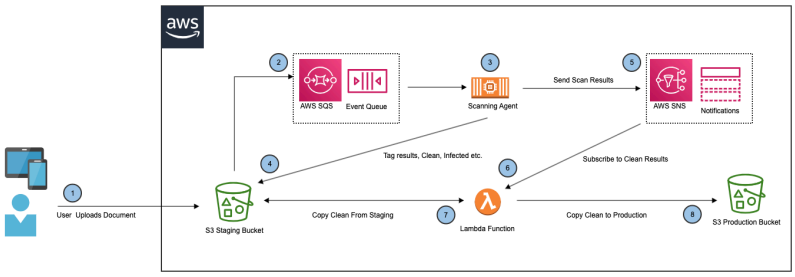
In order to raise an event, the bucket requiring scanning must be enabled for event-driven protection.

The scanning function runs in parallel to the existing application workflow and requires a limited amount of additional programming effort. This pattern will enable a two bucket system as this allows a physical separation between a staging bucket and production bucket.

Two Bucket System

The two bucket system allows a physical separation between the ingestion of files and production bucket. This allows separating incoming objects from the production bucket until they are scanned; this way they cannot be accessed by the downstream system until deemed safe.

This approach requires the creation of a staging bucket as the landing area for all uploads. To leverage the real-time scan result notifications, subscribe to the Notifications SNS topic that Cloud Storage Security publishes to. This will allow you to take real-time action (copy/move) on each file as it is scanned based on the scan results



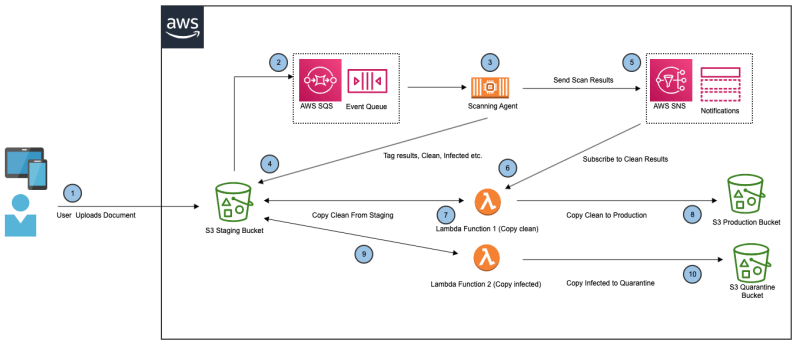
1. A 3rd party uploads a document to the Staging Bucket. The S3 bucket is configured to raise an event when an object is stored.
2. The event is placed in the SQS event queue for processing.
3. Scanning agent read from the SQS queue and scans the approperiate file.
4. The file is modified with the appropriate tag in the S3 Staging bucket.
5. Scanning results are then published to the SNS queue.
6. The lambda function is configured to subscribe to the SNS services and is notified when a file has been scanned.
7. Lambda function then copies the "clean" file from the staging bucket to the S3 production bucket.
8. "Clean" file lands in the S3 production bucket for further processing

In the two bucket system, the files tagged "infected" would either remain in the staging bucket or be deleted. If deleted, the lambda function can be configured to delete "infected" tagged files with a simple if/else statement.

Three Bucket System

The three bucket system allows a physical separation between the ingestion of files and production bucket with the added quarantine bucket where files with a postive scan result can be moved and investigated further by Security. This allows separating incoming objects from the production bucket until they are scanned, and moving infected files to a addition quarantine bucket for future analysis; as with the case of the two bucket system, the files cannot be accessed by the downstream system until deemed safe.

This approach requires the creation of a staging bucket as the landing area for all uploads. To leverage the real-time scan result notifications, subscribe to the Notifications SNS topic that Cloud Storage Security publishes to. This will allow you to take real-time action (copy/move) on each file as it is scanned based on the scan results.



Steps 1-8 are the same as the two bucket system except:

- Steps 9-10 could involve a second Lambda function to copy the infected file to the S3 quarantine bucket for further analysis or one Lamba function can be used with an if/else statement to move the clean or infected scanned file to the appropriate bucket.

Diagram

Use Cases

Goals & Benefits

Limitations

Components/Services

When To Use

Related Patterns

Security

Cost Model

- Chargeback (if any) to business unit for deploying this pattern

Deployment Strategy

- Overview of how this pattern can be brought to life including link to any reference implementation e.g. Terraform script to spin up environment for this pattern

Review History

Version #	Changes	Solution Architect	Review Date	Reviewer(s)	Approved Date	Approver(s)	Notes

Appendix

References

- Links to documentation leveraged to develop this pattern